

Haven

Session-nyckelrälsen, delegat-exponeringen och ERC-7710-genombrottet

Sessionsrapport — 2 juli 2026

4	epics/ADR stängda	#719 · #733 · #713 · #452
19	PR:ar mergade till dev	alla CI-gröna, money-path ägargodkända
8	on-chain-bevis	Base Sepolia, via produktionsvägar
6 799	rader ny kod	~40 nya filer, 697 backend-tester gröna
6	riktiga buggar/hål	hittade och fixade under live-körning
6	nya CI-invarianter	non-custody maskinbevisas på varje PR

1. Sammanfattning — vad hände idag?

Dagen började med en fråga: **klaras Smart Sessions att uttrycka Havens policyer på kedjan?** Den slutade med att Haven har en komplett, live-bevisad produktionsräls för sessionsnycklar, ett färdigmitigerat hot-EOA-fönster, och ett bevisat prototypsvar på den strukturella slutfrågan — att en smart-kontobetaling kan gå **direkt** till merchanten utan mellanhänder.

Tre stora arbetsströmmar, i ordning: **(1) Stage 2-epiken #733** — session-nyckelrälsen byggdes från grunden i produktion (fem foundation-slices + sex acceptansgates), live-verifierad med riktiga betalningar genom API:t. **(2) Epic #713** — tre mitigeringar av delegatens in-flight-exponering i x402-flödet. **(3) Prototyp #452** — ERC-7710-direktsettlement, den strukturella fixen som gör att exponeringsfönstret inte ens existerar.

Allt levererades enligt husets arbetssätt: varje issue en egen PR med tester, CI-gates, dokumentplikt och — för allt som rör pengavägar — ditt uttryckliga merge-godkännande. Sex riktiga buggar hittades *under* live-körningarna och fixades på plats; ingen mörkades.

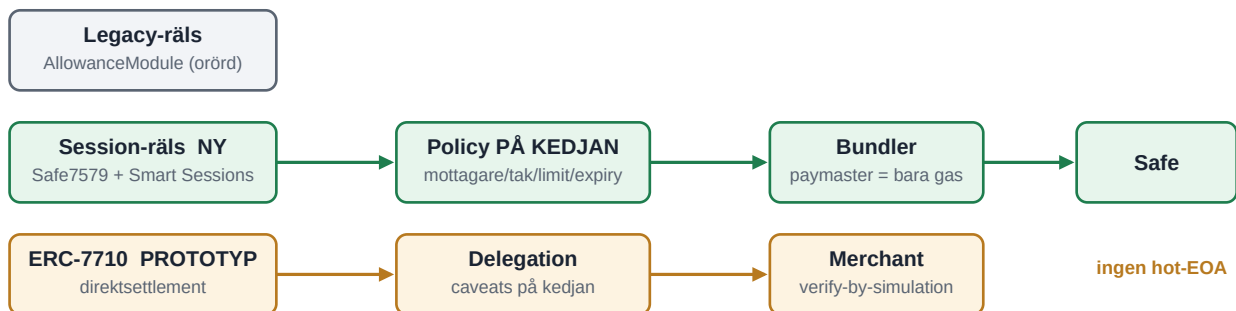
2. Arkitekturen — från en räls till tre

Haven hade en enda exekveringsräls: Safe:ns **AllowanceModule** (belopp + återställningsperiod, relayern betalar gas). Den fungerar men kan inte uttrycka policy-roadmapen — och kritiskt: en delegat kan betala *vilken mottagare som helst* inom sin allowance. ADR #719 föreslog efterträdaren: **ERC-4337 med sessionsnycklar** (Safe7579-adaptern + Smart Sessions), där hela policyn — mottagarlista, per-tx-tak, kumulativ gräns, utgångstid — bor **på kedjan**, owner-signerad, och där Haven inte kan vidga någonting.

FÖRE (en räls)



EFTER (tre räls, per konto-flagga, fail-closed till legacy)



Figur 1 — Före: allt genom AllowanceModule. Efter: per-konto-routing (fail-closed till legacy), session-rälsen med on-chain-policy, och 7710-prototypen där merchanten betalas direkt.

Nyckelprinciper som bevaras på alla räls: **non-custody** (Haven signerar aldrig värde — sessionsnyckeln stannar hos kunden, ownern signerar policyer, paymastern betalar bara gas och kan bara *vägra* sponsra) och **additivitet** (migrationen är EN owner-tx; den klassiska Safe-vägen fortsätter fungera efteråt, vilket också är fallback-mekanismen om bundlern får utfall).

3. Kodstrukturen — vad som byggdes var

Grönt [NY] = ny fil idag. Gult [ÄNDR] = ändrad. Strukturen speglar ansvarsfördelningen: ren *konstruktion* i lib/ (testbar utan nätverk), *routing* i routes/, *operatörsverktyg* i scripts/, och allt experimentellt i qa-agent (publiceras aldrig).

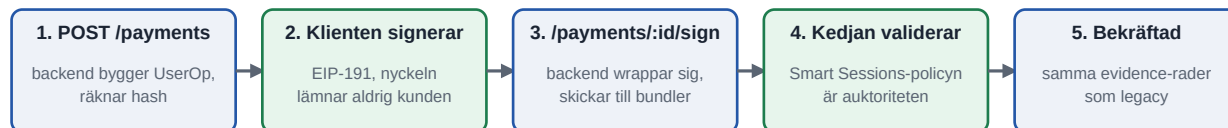
```
packages/
+-- backend/
|   +-- src/lib/
|   |   +-- execution-rail.ts           [NY]   routingbeslutet: vilken räls? (fail-closed)
|   |   +-- session-rail.ts           [NY]   UserOp-konstruktion + bundler-submit (watch-only owner)
|   |   +-- session-policies.ts       [NY]   Haven-policy -> Smart Sessions-session (permissionId)
|   |   +-- session-rotation.ts       [NY]   refill: deterministiska perioder, atomiskt byte
|   |   +-- safe7579-provisioning.ts   [NY]   migrationens EN-owner-tx (batch, ABI pinnad v1.0.2)
|   |   +-- delegate-balance-monitor.ts [NY]   timvis skanning: lingering/damm (läsande)
|   |   +-- machine-payments.ts       [ÄNDR] session-gren i authorize + exakt-beloppsvakt
|   |   +-- machine-payment-evidence.ts [ÄNDR] post-settle-avstämning (residue-flagga)
|   |   +-- sweep.ts                 [ÄNDR] 300s-fönstret motiverat vid konstanten
|   |   +-- __tests__/non-custody.invariants.test.ts [ÄNDR] +invarianter 5-10
|   +-- src/routes/
|   |   +-- payments.ts               [ÄNDR] session-gren i create + /sign, nyckel-redaktion
|   |   +-- x402.ts                   [ÄNDR] replay-beloppsvakt (#716)
|   +-- src/db/migrations/
|   |   +-- 036_execution_rail.ts     [NY]   per-konto rälsstate + pinnat intent-state
|   +-- scripts/
|   |   +-- check-bundler.ts          [NY]   vendorhälsa +-- check-attestation.ts [NY]
|   |   +-- check-delegate-balances.ts [NY]   saldotabell +-- rotate-session-live.ts [NY]
+-- sdk/ (publiceras till npm – INGA tunga beroenden tillförda)
|   +-- src/
|   |   +-- signer.ts                 [ÄNDR] +signUserOpHashForSession (EIP-191, skild från raw)
|   |   +-- x402.ts                   [ÄNDR] 600s-tak på merchantens fönster (två sömmar)
+-- qa-agent/ (privat – pilot- och DoD-verktyg)
|   +-- src/pilot/
|   |   +-- dod-payment.ts            [NY]   DoD-drivaren (vägrar legacy-schema)
|   |   +-- enable-agent-session.ts   [NY]   owner-tx: aktivera session + SQL-utskrift
|   |   +-- create-dod-agent.ts       [NY]   dev-user + Safe-import + agent via API
|   |   +-- x402-7710-buyer.ts        [NY]   ERC-7710-köparen (MetaMask-stacken)
+-- demo-merchant-mcp/
|   +-- src/x402.ts                   [ÄNDR] erc7710-rälsen (parallell session, #750)
+-- docs/
|   +-- operations/session-rail-vendor-ops.md [NY]   runbook: kredential/policy/utfall
|   +-- research/session-key-pilot-report.md  [NY]   go/no-go med all evidens
|   +-- research/non-custody-verification.md  [ÄNDR] +session-invariant-tabellen
```

Mönstret att lägga märke till: **konstruktion skildes från exekvering överallt**. buildProvisionBatch, buildHavenPolicySession, buildRotationPayload och prepareSessionTransfer är rena funktioner som enhetstestas offline — nätverk och signering sker i tunna, granskningsbara skal. Det är därför 697 tester kan vara gröna utan en enda kedjeanslutning i CI.

4. Session-nyckelrälsen — hur den fungerar

4.1 En betalning, steg för steg

En sessionsbetalning genom produktions-API:t



Fail-closed: intentet PINNAR räls + permissionId + UserOp vid steg 1 —
verifiering och exekvering sker alltid på rälsen vars hash kunden signerade.

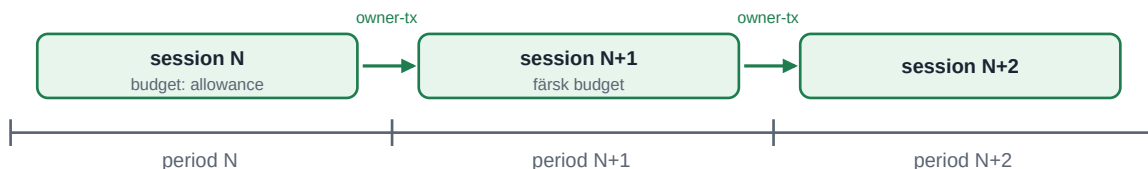
Figur 2 — Prepare/submit-uppdelningen (beslut #737): backend konstruerar, kunden signerar. Exakt samma tillitsmodell som AllowanceModule-rälsen redan hade — bara hashen och prefixet är nya.

Det viktiga är vad som **inte** händer: backend har ingen nyckel som kan signera (Safe-"owner" i konstruktionen är en *watch-only*-stub vars signeringsmetoder kastar — CI-pinnat). Sponsringen (Pimlico-paymastern) ger per-agent-gasbudgetar som **avslår före kedjan** när de är slut — bevisat live åt båda hållen under #738-verifieringen.

4.2 Refill utan egen Solidity — rotationen

Smart Sessions saknar AllowanceModulens självåterställande budget — `usage.limit` är en livstidsgräns. Lösningen: tiden delas i fasta perioder ur agentens befintliga `reset_period_min`, och varje period får sin egen deterministiska session.

Refill via deterministisk rotation — inga schemaläggningstillstånd



`salt = keccak(agentId, periodindex) => permissionId` kan beräknas statelöst av alla parter
Rotationen = EN owner-tx: ta bort gammal + aktivera ny ATOMISK (ingen lucka, ingen dubbelspendering)

Figur 3 — Eftersom saltet härleds ur (agent, periodindex) kan permissionId beräknas av alla parter, när som helst: "är rotation dags?" är en ren jämförelse, inget schema lagras. Live-bevisad: rotations-tx + färsk-budgetbetalning genom API:t.

4.3 Gates som stängde epiken

Gate	Utfall
#737 UserOp-konstruktion	Backend-wrappad; publicerade SDK:n förblir fri från permissionless/module-sdk
#739 Foundation (5 slices)	Signer-variant, konstruktion, provisionering, sessionsskapande, routing+migration 036
#734 Rotation	Deterministiska perioder, atomiskt byte — live-bevisad hela cykeln
#735 Attestering	Verifierat GLOBALT frånvarande (positiv kontroll bevisade metoden) -> dokumenterad icke-gating + körbar omkontroll
#736 CASP + CI	Invarianter 5-10 maskinbevisar perimetern; copy-sign-off bokförd, rapportens §5 kanonisk
#738 Vendor-ops	Runbook + hälsoprober; sponsringsbudget bevisad åt båda håll; nyckel roterad

5. Delegat-exponeringen — försvarsdjup i fyra lager

Standard-x402 tvingar medel genom en het delegat-EOA: Safe:n finansierar delegaten, delegaten betalar merchanten (EIP-3009). Mellan de två stegen ligger beloppet **utanför varje policylager**. Epiken redesignade inte flödet — den minimerade fönstret och gjorde varje anomali synlig:

Försvarsdjupet runt x402:s hot-EOA-fönster (epic #713)



Strukturella fixen (fönstret försvinner helt) = ERC-7710-rälsen — bevisad som prototyp samma dag (#452)

Figur 4 — Varje lager fångar det föregåendes miss. Sista raden är dagens poäng: 7710-rälsen tar bort fönstret helt, och den bevisades samma kväll.

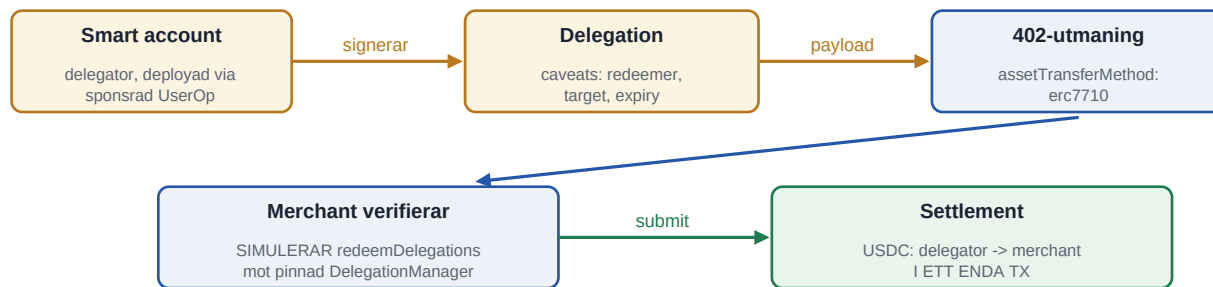
Två riktiga hål täpptes på vägen

- **Obegränsat merchantfönster (#715):** x402-biblioteket satte `validBefore = nu + merchantens begärda timeout` — utan tak. En illasinnad merchant kunde begära ett års giltighet på en läckt signatur. Nu: 600s-tak vid BÅDA sömmarna (parse + pre-sign), klampat i stället för avvisat så betalningar flödar vidare.
- **Replay-beloppssluckan (#716):** vid idempotency-replay exekverade x402-routen *requestens* belopp medan huvudboken bokförde intentets. En replay med annat belopp = pengar flyttas som inte bokförs. Nu: fail-closed 409-vakt med båda talen i felet.

6. ERC-7710 — den strukturella fixen, bevisad

Frågan tre spår väntade på: kan en smart-kontobetalning gå direkt till merchanten? Merchant-halvan fanns (#750, parallell session); i kväll byggdes köparen och hela kedjan kördes live — två gånger:

ERC-7710: merchanten betalas DIREKT från smart-kontot



Ingen delegat-EOA håller någonsin medlen — in-flight-fönstret existerar inte på denna räls.

Figur 5 — MetaMask-delegatorn deployades via SPONSRAD UserOp genom samma pilotbundler som session-rälsen använder: de två spåren delar redan infrastruktur.

Interop-fynden är prototypens egentliga värde: (1) x402-klientens default-selector tar merchantens *första* betalalternativ — explicit selector krävs för `erc7710`; (2) merchanten svarar vid *settle-submission*, så evidensläsare måste polla bekräftelsen; (3) MetaMasks experimentella provider och vår merchant interopererar **utan en enda shim**.

7. Bevisen — åtta transaktioner på Base Sepolia

#	Vad bevisades	Tx (sepolia.basescan.org/tx/...)
1	Migration: vanilla Safe -> ERC-7579, EN owner-tx, additiv (#721)	0x47b078f9...
2	DoD: policy-bunden sessionsbetalning genom produktions-API:t (#739)	0x299ebf4b...fcd191c8
3	Rotation: gammal bort + ny in, atomiskt i samma tx (#734)	0x72dbc9d2...862f6286
4	Färsk periodbudget efter rotation, genom API:t (#734)	0xc415d75f...7319e8e6b8a
5	Betalning genom aktiv sponsorship-policy (#738)	0xa55ef986...976852f2d6
6	Policy-avslag PÅ KEDJAN: 0,06 > taket -> validateUserOp revert, inget skrivs	(502 före kedjan — det är poängen)
7	ERC-7710 direktsettlement, körning 1 (#452)	0xb0019255...03f53f25
8	ERC-7710 direktsettlement, körning 2 — rent, exakt pris (#452)	0xcb432a56...ffa7bbd6

Alla länkar i klickbar form finns på respektive stängt issue (#739, #734, #738, #452).

8. Buggar som hittades live — och lärdomarna

Bugg	Rot-orsak	Lärdom
Sessionssignaturer underkändes trots korrekta policyer	OwnableValidator kräver EIP-191, inte rå ECDSA (#731)	Två signaturscheman = två skilt namngivna funktioner + test som bevisar att de INTE är utbytbara
Verifiering föll direkt efter lyckad tx	Publika RPC:er är lastbalanserade — läsning träffade eftersläpande nod (#755)	Skriv ut tx-länken FÖRE verifiering; polla med backoff
500 på varje sessionsbetalning i dev	SQL-join mot agents.safe_address — kolumnen finns inte (#757)	Mockade tester validerar aldrig SQL mot riktigt schema — en real-pg-smoke är ett gap (se §9)
API-nyckeln läckte i felmeddelanden	Viem ekar hela request-URL:en (inkl. apikey) i sina fel; vi skickade dem oskrubbade (#764)	Varje vendor-felyta måste genom en redaktor; regressionstestat med exakt felformen
Sponsorship-policyn gjorde ingenting	Pimlico-policyer binder PER REQUEST, inte per API-nyckel (#763)	Verifiera vendors bindningsmodell mot deras docs INNAN operatörssteget
Replay kunde flytta obokfört belopp	Idempotent reload exekverade requestens belopp, inte intentets (#716)	Idempotens utan likhetsvakt på nyttolasten är en halv idempotens

9. Vad kan förbättras — ärlig framåtblick

Prioriterat efter risk/värde. Inget av detta blockerar det som redan körs på testnet.

A. Produktifiering av session-rälsen

- **Migrations-UX:** dashboarden saknar rotationsprompter (owner måste signera refill-rotationen) och flip-knapp för `execution_rail`. Idag är det SQL — fungerar för pilot, inte för kunder.
- **SDK-schemastöd:** `sign_data.signature_scheme` finns i API-svaret men publicerade SDK:n väljer inte signerare automatiskt än — gamla SDK:er på migrerade konton skulle signera fel. Operatörsstyrtd idag; bör bli automatiskt.
- **Räckvidd:** bara POST `/payments + /sign` är session-kopplade. x402-routens inline-flöde och `/send` går fortfarande legacy (fungerar tack vare additiviteten, men bör konvergera).
- **Approval-kö-semantik:** på session-rälsen avslås över-policy-betalningar direkt (on-chain) i stället för att köas för ägargodkännande — en medveten skillnad som behöver ett produktbeslut före bred migrering.

B. Vägen till mainnet

- **Attesteringsbevakningen** (ops:check-attestation) bör få cron — idag manuell kadens. Registry-gating slås på när Rhinestone attesterar Smart Sessions (körbar procedur finns).
- **Gnosis:** v1.3.0-singletonen + Safe7579 behöver sin egen verifieringskörning innan något Gnosis-konto migreras.
- **Stage 3:** pensionera legacy-rälsen för migrerade konton — då stängs också #717/#718 (relay-budgetar/nonce-serialisering) på riktigt.

C. ERC-7710-spåret (efter prototypen)

- **Safe-port:** prototypens delegator är MetaMask Hybrid; Havens konton är Safe7579. Delegation-framework-kompatibiliteten med Safe är nästa verifiering.
- **Ledger-koppling:** settle-svaret bär evidensfälten men skrivs inte in i `machine_payment_evidence` än — krävs för att bokförings-moaten ska täcka rälsen.
- **Budget->caveats-översättning + vendor-facilitator + audit** (#431-scopet) före riktiga medel.

D. Teknisk skuld/testgap

- **Schema-drift-gapet:** tre fixtures saknade kolumner som riktiga schemat garanterar; `safe_address`-buggen nådde dev. En liten real-Postgres-smoke i CI (migrationer + en SELECT per kritisk query) skulle fånga klassen.
- **Monitors larm är loggar:** delegate-monitorn WARN:ar i Railway-loggar — bör få riktig alerting (webhook/dashboard) när volym finns.
- **Pilot-städning:** qa-agent/pilot har vuxit; skripten är dokumenterade men en README-indexsida över vilket skript som gör vad vore billig hjälp.

10. Bilaga — dagens PR:ar i ordning

PR	Innehåll
#731	Pilotens EIP-191-fix (rot-orsaken bakom #722)
#732	Pilotrapport + go/no-go (#724)
#740	Beslut: backend-wrappad UserOp-konstruktion (#737)

PR	Innehåll
#746	SDK: signUserOpHashForSession (#741)
#748	Backend: provisioneringsbatchen (#743)
#749	Backend: sessionsskapande från agentpolicy (#744)
#751	Backend: UserOp-konstruktion + bundler-submit (#742)
#753	Routing + migration 036 (#745) — code-owner-granskad
#755	Fix: RPC-lagg i sessionsverifiering
#757	Fix: execution-rail-joinen (safe_address-spöket)
#758	Rotation — refill-paritet (#734), live-bevisad före merge
#759	Non-custody-invarianter 5-10 (#736 CI-halvan)
#760	Attesteringsbeslutet C+A + körbar omkontroll (#735)
#761	CASP-copyjustering A1 (#736)
#762	Vendor-ops-runbook + bundlerhälsa (#738)
#763	sponsorshipPolicyId per request (#738)
#764	Säkerhet: nyckel-redaktion i felytor
#765	Delegate-saldomonitorn (#714)
#766	600s-fönstertak + sweep-policy-pin (#715)
#767	Exakt-beloppsvakt + settle-avstämning (#716)
#768	ERC-7710-köparen, live-bevisad (#452)

Rapport genererad 2026-07-02 · Haven-AI (d-hinders) · dev-branchen · Alla on-chain-referenser: Base Sepolia (chain 84532)